Ethical Hacking - Assessment Tool II: Assignment

Course Code: ITA14 | Course Outcome: CO1

Name / Reg No: _____

Code of Conduct: I certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

Question 1: Vague one-line authorization, critical vulnerability found out of scope

A company hires you to test its network with only a one-line email authorization and no defined scope. Halfway through, you find a critical vulnerability in a system not mentioned in the email. Do you exploit it to prove impact?

Answer: No. I do not exploit it. I stop, document, and report it, and ask for written scope clarification.

Justification

- **Authorization is the line between ethical hacking and a crime.** Laws such as the Computer Fraud and Abuse Act (US), the Computer Misuse Act (UK) and the Information Technology Act, 2000, Sections 43 and 66 (India), criminalise unauthorised access. A vague email does not clearly cover the unlisted system, so exploiting it could be unauthorised access.
- **Ownership is unknown.** The system may belong to a third party (cloud provider, vendor, partner, subsidiary). The client cannot authorise testing of assets it does not own.
- **Do no harm and minimise risk.** I do not know the system's role, so exploiting it could crash a critical service or expose sensitive data.
- **Proof of impact is not required.** Evidence that the vulnerability exists (version banner, safe non-intrusive check, screenshot, CVSS rating) is enough for the client to act. Exploitation is only justified when it is explicitly authorised.
- **Professional integrity and responsible disclosure.** The right action is prompt, confidential reporting to the client contact, not unilateral action.

What I would do

- Stop any further interaction with that system and record exactly what was observed, with timestamps.
- Notify the designated client contact immediately through a secure channel, because a critical issue should not wait for the final report.
- Request a written scope amendment (in-scope assets, IP ranges, permitted techniques, testing windows, emergency contacts) before touching the system again.
- If the client authorises it in writing, test it under agreed safe conditions. Otherwise leave it as a reported finding.
- Decline to continue the engagement under such a loose authorization, or insist on a proper contract, Statement of Work and Rules of Engagement (RoE).

Question 2: SQL injection against a production database with real customer financial data

The production database contains real customer financial data and your test plan calls for exploiting SQL injection. How do you proceed without causing harm, and what precautions should have been taken before the engagement?

How to proceed safely

- **Prove the flaw, not the data.** Confirm injection with non-destructive, read-only techniques (for example error-based or boolean checks, or retrieving the DB version or current user). Do not dump tables or browse customer records.
- **No write operations.** Never use INSERT, UPDATE, DELETE, DROP or stacked queries, and avoid time-based payloads that load the server.
- **Minimise data exposure.** If a record is incidentally seen, stop, do not copy or store it, and mask or redact any proof-of-concept evidence (for example show only the first few characters or the row count).
- **Throttle and monitor.** Use low request rates, test in the agreed window, keep a client contact on standby, and stop immediately if performance degrades.
- **Prefer a safer environment.** Ask to reproduce the test on a staging copy with synthetic or masked data. If testing production is required, get explicit written approval for it.
- **Report immediately** if the injection is critical, and recommend fixes: parameterised queries / prepared statements, input validation, least-privilege DB accounts, a WAF, and error-message hardening.

Precautions that should have been taken before the engagement

Precaution	Purpose
Signed contract, SoW and RoE	Defines scope, allowed techniques, targets, timing and what is explicitly forbidden (for example data extraction).
Non-Disclosure Agreement (NDA)	Legally protects confidential customer and business information.
Data-handling rules	Compliance with applicable regulations (PCI-DSS, GDPR, India's DPDP Act 2023): encrypted storage of evidence, retention limits, secure destruction.
Pre-engagement backups and rollback plan	Lets the client restore data if anything is altered.
Emergency contacts and escalation path	Rapid response if something breaks or sensitive data is exposed.
Testing window and change freeze	Reduces business impact and avoids confusion with real attacks.
Professional liability insurance	Covers accidental damage.
Third-party authorisation	Written consent from hosting or payment providers where they own part of the infrastructure.

Question 3: Accidental denial of service on a live production server (black-box test)

During a black-box test you accidentally trigger a DoS condition on a live production server, causing an outage. What should you have done to prevent it and what is your responsibility now?

What I should have done to prevent it

- **Agree on rules for risky tests in the RoE:** whether DoS, stress, fuzzing or brute-force testing is allowed, and which systems are fragile or business-critical.
- **Scan and test gently:** use conservative scan settings (lower threads, rate limiting, no 'dangerous' or 'DoS' check categories), start with passive and low-impact enumeration, and escalate gradually.
- **Test in a safe window** (off-peak) with the client's operations team on call and monitoring the target's health.
- **Prefer staging or replicas** for potentially disruptive exploits, and never run untested exploits or fuzzers against production.
- **Have an established kill-switch and communication plan:** a clear 'stop testing' signal, health-check monitoring, and a 24/7 contact.

My responsibility now

- **Stop testing immediately** and do not try to 'fix' the situation by experimenting further.
- **Notify the client at once** with honest details: what was done, exact time, targets, tools and payloads used. This allows quick recovery.
- **Support recovery:** provide logs and the exact steps that triggered the issue to help restore service and verify no data was corrupted.
- **Be transparent, never conceal the incident.** Hiding it would be unethical and could create legal liability.
- **Document an incident report:** timeline, root cause, impact, remediation, and lessons learned. Record it in the final report.
- **Review contractual and legal position:** check liability and insurance clauses, and cooperate with any client review. Resume only after the client agrees and the RoE is revised.
- **Accountability:** accept responsibility professionally, since an authorised tester remains responsible for foreseeable impact of their actions.

Question 4: Client wants the test hidden from its IT department

A client asks you to test their systems but insists you not inform their IT department, to test real-world detection capability. What are the ethical and practical risks, and how would you structure the engagement to protect yourself?

Such unannounced testing is legitimate and common (it is how red team and blind tests work), but it carries real risk.

Type of risk	Details
Legal / ethical	IT staff may treat activity as a real attack and involve law enforcement or the ISP. Without proof of authorization, the tester may be accused of unauthorised access. Employees may also be unfairly blamed or disciplined for 'missing' the test.
Practical	The defenders may take disruptive actions: shutting down systems, blocking IPs, restoring backups, or launching a full incident response, wasting resources and causing downtime. Real attackers could hide in the noise.
Trust / people	Staff morale and trust can suffer if they feel deceived. Monitoring of staff can raise privacy issues.
Business	Responses may trigger customer notifications, regulatory reports, or public statements based on a false alarm.

How to structure the engagement to protect myself

- **Get written authorization from an accountable executive** (CISO, CIO, CEO or legal head) who has the authority to approve it, and keep a signed 'get out of jail free' letter on me during testing.
- **Create a small 'white cell' / trusted agent group** (for example one or two senior people) who know about the test and can de-escalate if the blue team escalates.
- **Define scope, rules and limits in the RoE:** targets, techniques, hours, prohibited actions (no DoS, no real data exfiltration, no social engineering of named individuals if excluded), and success criteria.
- **Use unique identifiers:** fixed source IPs, tester tools, or a code word that allows the white cell to quickly confirm that an alert is the authorised test.
- **Set up a deconfliction process and emergency stop** with 24/7 contact numbers.
- **Check legal compliance** (contract, NDA, data-protection, employment and privacy laws, third-party permissions).
- **Keep detailed logs** of all actions and timestamps as proof of what was done.
- **Hold a debrief afterwards** with the IT team, framed as improving processes, not blaming people, and focus the report on detection gaps and recommendations.

Question 5: Red team exercise vs vulnerability assessment (bank scenario)

Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between a red team exercise and a vulnerability assessment.

Aspect	Vulnerability Assessment (VA)	Red Team Exercise
Goal	Find, list and prioritise as many weaknesses as possible (breadth).	Simulate a realistic adversary trying to achieve a specific objective, such as reaching core banking systems or the vault (depth).
Approach	Mostly automated scanning plus manual validation: network and web scanners, configuration reviews, patch checks, a physical checklist of locks, CCTV, badge readers and signage.	Goal-driven and stealthy: reconnaissance (OSINT), phishing, exploitation, privilege escalation, lateral movement, persistence; physical intrusion by tailgating, badge cloning, social engineering of staff.
Exploitation	Generally not exploited, or only lightly verified.	Vulnerabilities are chained and exploited to prove real business impact, within limits.
Awareness	IT and security teams know about it.	Usually only a small group (white cell) knows. Tests detection and response of the blue team.
Duration	Days to a couple of weeks.	Weeks to months.
Output	Prioritised list of vulnerabilities with severity (CVSS) and fixes.	Attack narrative, kill chain, detection and response gaps, lessons for the bank's security program.
Rules of Engagement	Scope list of IPs, applications and branches; scan windows; no exploitation or DoS; access to the physical premises with escorts.	Defined objectives ('crown jewels'), allowed TTPs, out-of-bounds systems (live payment switches, ATM networks, customer funds), social-engineering limits, emergency stop, deconfliction contacts.

Ethical considerations (both, with differences)

- **Written authorization is mandatory** in both cases, including approval from the bank's board or legal head and, for physical testing, from the building owner and any third-party landlords or security contractors. Regulator expectations (for example RBI guidelines in India) should be respected.
- **VA ethics:** avoid disrupting services, protect scan output (it is a roadmap for attackers), and handle findings confidentially.
- **Red team ethics:** since it involves deception, I must avoid harming employees (no humiliating or punishing individuals, no personal-life targeting, no coercion), never touch real customer funds or personal data beyond what is needed to prove access, and avoid creating physical danger (for example, no weapons, no forced entry that could trigger armed response).
- **Physical testing safety:** carry an authorization letter and a contact number for the white cell, so staff or police can verify the test and not treat the tester as a real criminal.
- **Data handling and reporting:** encrypt and securely destroy evidence, report critical issues immediately, and follow responsible disclosure.

Bank scenario summary: For the vulnerability assessment I would scan the bank's internal and external network, web banking apps and branch Wi-Fi, and audit branch physical controls using a checklist, delivering a prioritised remediation list. For the red team I would be given an objective such as 'obtain access to the core banking database', then combine OSINT and phishing, exploit a weak VPN or web app, move laterally, and attempt a physical entry at a branch to plant a device, all under tight RoE and with a white cell watching, and then report how well the bank's staff and tools detected and stopped each step.

Conclusion

Across all five scenarios, the same principles apply: **authorization and defined scope, do no harm, minimise data exposure, confidentiality, transparency and honest reporting, legal compliance, and responsible disclosure.** An ethical hacker always works from a written agreement, stops and asks when something is unclear, and treats the client's systems and data as if they were their own.